CHALLENGE SHEET

Duckwebview

DuckWebView is an Android security challenge demonstrating risks of insecure WebView JavaScript bridges.

DIFFICULTY	TRACK	HOST PORT	LAB ID
MEDIUM	WEB	8080	duckwebview

EASY | MEDIUM | HARD | INSANE

VERIFY THE SOLVE

```
python3 ../scripts/check.py duckwebview
```

Brief

DuckWebView is a legacy Android archive preview application.

You are provided with an Android APK. Analyze the application, investigate its archive metadata, identify the exposed JavaScript bridge, and determine whether user-controlled HTML can invoke native functionality to retrieve sensitive information.

The challenge requires Android application analysis and interaction with the WebView functionality.

Goal

Retrieve the challenge flag by exploiting the intended vulnerability in the DuckWebView application.

The flag follows this format:

```
duck\{...\}
```

Difficulty

Medium

This challenge requires multiple investigation steps, including APK enumeration, Base64 decoding, native-code inspection, JavaScript bridge identification, and exploitation through user-controlled HTML.

Prerequisites

- Basic knowledge of Android application security.
- Familiarity with APK analysis tools such as JADX.
- Basic knowledge of JavaScript and HTML.
- Familiarity with Android WebView functionality.
- Basic understanding of client-server communication.

Setup

Install the provided APK on a compatible Android emulator or test device.

The archive backend must also be running for the intended flag retrieval workflow.

For local development, start the backend from the lab directory:

```
docker compose up --build -d
```

The local development portal is available at:

```
http://localhost:8080
```

Health check:

```
http://localhost:8080/health
```

The standard Android Emulator can reach a service published on the host machine through:

```
10.0.2.2:8080
```

A physical Android device requires a reachable backend address and suitable network configuration.

Reset

To reset the local backend environment:

```
docker compose down --remove-orphans
docker compose up --build -d
```

Reinstall or relaunch the APK as needed.

Rules

- Perform testing only against the provided challenge environment.
- Do not target external systems or applications.
- Do not modify the challenge source code while solving it.
- Do not commit real challenge flags or populated `.env` files to a public repository.

Flag Format

```
duck\{...\}
```